

# API Requirements and RBAC

Which SyteLine APIs the chatbot needs, why each one is needed — explained step by step with examples — and how SyteLine permissions (RBAC) apply to every call

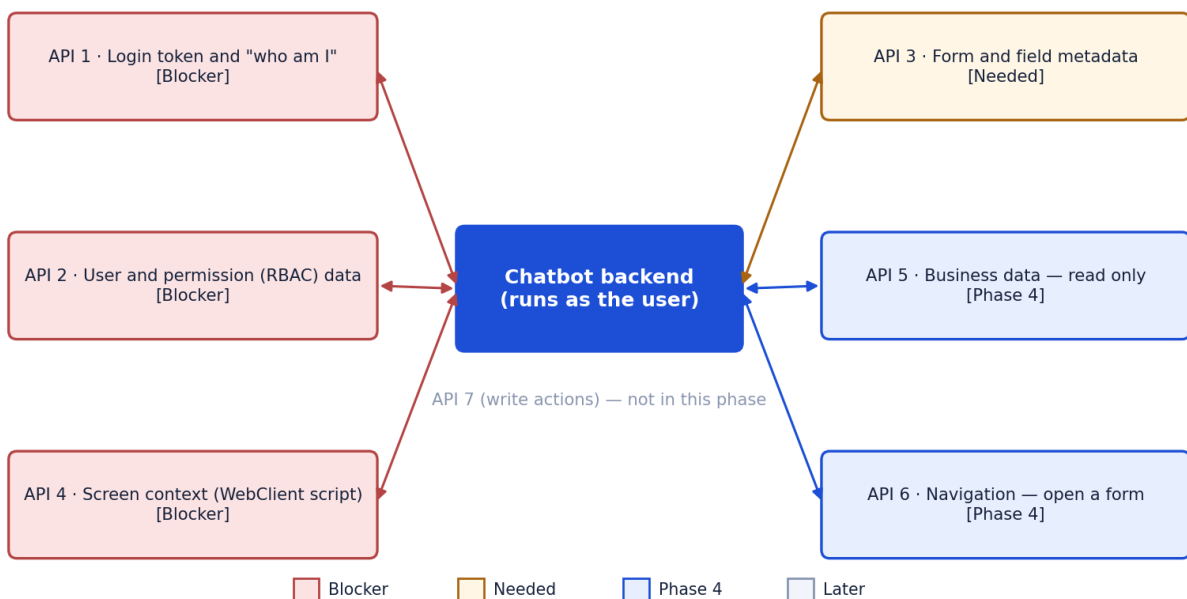
| Item              | Detail                                                                                         |
|-------------------|------------------------------------------------------------------------------------------------|
| Document version  | 1.0 — for review                                                                               |
| Date              | 25 September 2026                                                                              |
| Prepared by       | Chatbot development team                                                                       |
| Prepared for      | SyteLine technical and security team                                                           |
| Environment       | SyteLine WebClient, configuration AIDEMO                                                       |
| Related documents | SyteLine_Chatbot_Integration_Requirements.docx ·<br>SyteLine_RBAC_Permission_Requirements.docx |
| Action requested  | Confirm each API in the "Please confirm" tables and tick the checklist in section 6            |

## 1. Summary

The chatbot needs seven groups of SyteLine APIs. Almost all business data in SyteLine is read through one standard service — the Mongoose IDO Request Service — so most items below are really "which IDOs and properties the chatbot may read". Request formats shown are the usual Mongoose REST form and are illustrative: the SyteLine team must confirm the exact endpoints and names for this version.

### The one rule that makes RBAC work

Every business-data call is made with the logged-in user's own token — never a shared admin account. SyteLine then applies that user's permissions to every call automatically, and the chatbot can never show more than the user could see in SyteLine.



| API                                  | Why we need it (one line)                                                                           | Example question                                              | RBAC by SyteLine?                                                           | Priority |
|--------------------------------------|-----------------------------------------------------------------------------------------------------|---------------------------------------------------------------|-----------------------------------------------------------------------------|----------|
| 1. Login token and "who am I"        | The user must not log in a second time — the chatbot has to reuse the SyteLine login.               | Priya (Sales Rep) opens the chat after logging in to SyteLine | Yes                                                                         | Blocker  |
| 2. User and permission (RBAC) data   | To answer "What can I do on this form?" exactly as SyteLine is configured.                          | Can I release the credit hold on this order?                  | This IS the RBAC data                                                       | Blocker  |
| 3. Form and field metadata           | To link what is on screen to the data behind it.                                                    | What does this field mean?                                    | Mostly not sensitive                                                        | Needed   |
| 4. Screen context (WebClient script) | Users ask about "this order", "this field", "this screen" — the chatbot must know what "this" is.   | Why can't I ship this?                                        | No                                                                          | Blocker  |
| 5. Business data — read only         | To answer questions about real records: status, holds, balances, due dates.                         | Why is order S000123 on hold?                                 | YES, fully                                                                  | Phase 4  |
| 6. Navigation — open a form          | Users want to go straight to the right screen after the answer ("open the invoice for this order"). | Open the invoices for this customer                           | Yes                                                                         | Phase 4  |
| 7. Write actions — NOT in this phase | Not needed now: the proof of concept is read-only. Asked only to plan future phases.                | Create an order for C000451                                   | When enabled later, SyteLine enforces Insert/Update/Execute rights per user | Later    |

## 2. Each API explained step by step

Every API below follows the same layout: what it is, why we need it, a worked example with each step, an illustrative request, what goes wrong without it, how RBAC applies, and what the SyteLine team should confirm.

### API 1 — Login token and "who am I" [Blocker]

#### What it is

A way for the chat panel to receive the logged-in user's short-lived SyteLine session token, and an endpoint the chatbot backend calls to validate that token and learn who the user is.

#### Why we need it

- The user must not log in a second time — the chatbot has to reuse the SyteLine login.
- The chatbot must know the REAL user (not a name typed in the browser) before it answers anything.
- Every later API call carries this token, so SyteLine applies that user's permissions automatically.

#### Step-by-step example: Priya (Sales Rep) opens the chat after logging in to SyteLine

| Step | What happens                                                                      | Who / which API   |
|------|-----------------------------------------------------------------------------------|-------------------|
| 1    | Priya logs in to SyteLine WebClient as usual.                                     | SyteLine          |
| 2    | She clicks the chat button; WebClient passes her session token to the chat panel. | WebClient → panel |
| 3    | The panel sends her first question with the token to the chatbot backend.         | Panel → backend   |
| 4    | The backend calls "who am I" with the token.                                      | Backend → API 1   |
| 5    | SyteLine answers: user priya.s, configuration AIDEMO, site MAIN.                  | API 1 → backend   |
| 6    | The chatbot now answers as Priya, with Priya's rights — no second login.          | Chatbot           |

#### Illustrative request and response (to be confirmed)

```
GET /IDORequestService/ido/token/AIDEMO          (or ION API OAuth2 token)
→ { "Token": "b/XdI6I..." }
```

```
Validate / who am I (endpoint to be confirmed)
→ { "user": "priya.s", "configuration": "AIDEMO", "site": "MAIN" }
```

#### Without this API

The user would need a separate chatbot login, or the chatbot would have to trust whatever name the browser sends — a serious security hole.

#### How RBAC applies

Yes — the token IS the user. Every call made with it gets exactly that user's rights.

#### SyteLine team — please confirm

| Please confirm                                                       | Answer (SyteLine team) |
|----------------------------------------------------------------------|------------------------|
| How does the chat panel get the token from the WebClient session?    |                        |
| Which endpoint validates it and returns user / configuration / site? |                        |
| Token lifetime, and what happens on logout or timeout?               |                        |
| Mongoose IDO REST token, or ION API gateway (.ionapi OAuth2)?        |                        |

## API 2 — User and permission (RBAC) data [Blocker]

### What it is

Read access to the security records: the user, their authorization groups, the object authorizations (privileges on forms and IDOs) for the user and their groups, their sites and licensed modules.

### Why we need it

- To answer "What can I do on this form?" exactly as SyteLine is configured.
- To avoid suggesting forms, steps or actions the user is not allowed to use.
- To guard the parts SyteLine cannot see — the chatbot's own help content.

### Step-by-step example: Priya asks "Can I release the credit hold on this order?"

| Step | What happens                                                                                           | Who / which API |
|------|--------------------------------------------------------------------------------------------------------|-----------------|
| 1    | The chatbot knows the user is priya.s (API 1).                                                         | Chatbot         |
| 2    | It reads her groups: SALES_REP.                                                                        | Backend → API 2 |
| 3    | It reads SALES_REP's authorizations: Customer Orders = Read/Update; Credit Hold release = not granted. | Backend → API 2 |
| 4    | Result is cached for a few minutes, so the next question is instant.                                   | Chatbot (Redis) |
| 5    | Answer: "You can view and edit this order, but releasing a credit hold needs a Credit Manager."        | Chatbot         |

### Illustrative request and response (to be confirmed)

```
GET /IDORequestService/ido/load/MGCore.UserGroupMaps
  ?properties=UserName,GroupName&filter=UserName='priya.s'
→ [ { "UserName": "priya.s", "GroupName": "SALES_REP" } ]

GET /IDORequestService/ido/load/<object authorizations IDO>
  ?filter=GroupName='SALES_REP'
→ [ { "Object": "CustomerOrders", "Read": 1, "Update": 1, "Delete": 0 }, ... ]
(IDO names are examples – please confirm)
```

### Without this API

The chatbot could not explain permissions and might tell a user to do something SyteLine will refuse.

### How RBAC applies

This IS the RBAC data. It is read only to explain and to hide options — the real enforcement is still SyteLine itself on every data call (API 5).

### SyteLine team — please confirm

| Please confirm                                                                             | Answer (SyteLine team) |
|--------------------------------------------------------------------------------------------|------------------------|
| Exact IDO names for users, groups, user-group map, object authorizations, sites, licenses. |                        |
| Can a user read their own permissions, or is a read-only service account needed?           |                        |
| Rules: group vs user precedence, several groups, deny, Super User.                         |                        |
| Is there one call that returns effective permissions?                                      |                        |

## API 3 — Form and field metadata [Needed]

### What it is

Which IDO each form uses (Customer Orders → SLCos) and the property list of an IDO (field name, label, type).

### Why we need it

- To link what is on screen to the data behind it.
- To explain a field using its real SyteLine label.
- To request exactly the fields needed — never whole records.

### Step-by-step example: Priya is in the Credit Hold field and asks "What does this field mean?"

| Step | What happens                                                                                | Who / which API   |
|------|---------------------------------------------------------------------------------------------|-------------------|
| 1    | Screen context (API 4) says: form CustomerOrders, field CreditHold.                         | WebClient → panel |
| 2    | The chatbot looks up the form's IDO: SLCos.                                                 | Backend → API 3   |
| 3    | It reads SLCos property info: CreditHold = "Credit Hold", flag.                             | Backend → API 3   |
| 4    | It combines the label with the knowledge base article on credit holds.                      | Chatbot           |
| 5    | Answer: "Credit Hold marks this order as blocked from shipping until credit is released..." | Chatbot           |

### Illustrative request and response (to be confirmed)

```
GET /IDORequestService/ido/info/SLCos
→ { "Properties": [ { "Name": "CoNum", "Label": "Order" },
                    { "Name": "CreditHold", "Label": "Credit Hold" }, ... ] }
```

### Without this API

The chatbot would not know which data sits behind a screen or field, so screen-level answers would be vague.

### How RBAC applies

Mostly not sensitive. The chatbot still hides fields the user is not allowed to see (from API 2).

### SyteLine team — please confirm

| Please confirm                                                | Answer (SyteLine team) |
|---------------------------------------------------------------|------------------------|
| How to get the form → IDO mapping for Prospect-to-Cash forms? |                        |
| Is /ido/info available, or another metadata call?             |                        |

## API 4 — Screen context (WebClient script) [Blocker]

### What it is

Not a REST API: a supported WebClient script/event that tells the chat panel the current form, focused field, selected record key and site — and sends an update whenever the user moves.

### Why we need it

- Users ask about "this order", "this field", "this screen" — the chatbot must know what "this" is.
- Without it, every question needs the user to type IDs and form names.

### Step-by-step example: Priya has order S000123 open and asks "Why can't I ship this?"

| Step | What happens                                                                   | Who / which API   |
|------|--------------------------------------------------------------------------------|-------------------|
| 1    | WebClient event fires: form CustomerOrders, record CoNum = S000123, site MAIN. | WebClient script  |
| 2    | The script posts this to the chat panel (window.postMessage).                  | WebClient → panel |
| 3    | The panel sends it with the question to the backend.                           | Panel → backend   |
| 4    | "this" is resolved to order S000123 — no need to ask which order.              | Chatbot           |

### Illustrative request and response (to be confirmed)

```
{ "type": "ptc.context", "configuration": "AIDEMO", "site": "MAIN",  
  "form": { "name": "CustomerOrders", "caption": "Customer Orders" },  
  "field": { "name": "CreditHold" },  
  "record": { "ido": "SLCos", "keys": { "CoNum": "S000123" } } }
```

### Without this API

The chatbot cannot answer screen-level questions and has to ask "which order?" every time.

### How RBAC applies

No — it is NOT a security source. It only says what is open; identity comes from API 1 and rights from API 2 / Syteline.

### Syteline team — please confirm

| Please confirm                                                              | Answer (Syteline team) |
|-----------------------------------------------------------------------------|------------------------|
| Supported way to read active form, field and record in WebClient scripting? |                        |
| Which events fire when form / record / field change?                        |                        |
| Can the script postMessage to our panel, and from which origin?             |                        |

## API 5 — Business data — read only [Phase 4]

### What it is

Read access (load collection / invoke method) to the approved Prospect-to-Cash IDOs: customers, customer orders and lines, estimates/quotes, credit, shipments, A/R invoices and payments — always called with the user's own token.

### Why we need it

- To answer questions about real records: status, holds, balances, due dates.
- Documents explain HOW things work; only live data says what is TRUE right now for this record.

### Step-by-step example: Priya asks "Why is order S000123 on hold?"

| Step | What happens                                                                                                               | Who / which API |
|------|----------------------------------------------------------------------------------------------------------------------------|-----------------|
| 1    | Chatbot reads order S000123 with Priya's token: CreditHold = Yes, customer C000451.                                        | Backend → API 5 |
| 2    | It reads customer C000451 with Priya's token: credit limit 50,000; balance 62,300.                                         | Backend → API 5 |
| 3    | It combines the facts with the credit-hold article from the knowledge base.                                                | Chatbot         |
| 4    | Answer: "S000123 is on hold because C000451 is over its credit limit (62,300 vs 50,000). A Credit Manager can release it." | Chatbot         |

### Illustrative request and response (to be confirmed)

```
GET /IDORequestService/ido/load/SLCos
    ?properties=CoNum,CustNum,Stat,CreditHold&filter=CoNum='S000123'
→ [ { "CoNum": "S000123", "CustNum": "C000451", "Stat": "0", "CreditHold": 1 } ]

POST /IDORequestService/ido/invoke/<IDO>?method=<credit or aging method>    (if provided)
```

### Without this API

The chatbot can only explain processes in general; it cannot say anything about a specific order, customer or invoice.

### How RBAC applies

YES, fully — because the call runs as Priya. If she cannot see credit fields or another salesperson's customer, Syteline returns nothing, and the chatbot has nothing to reveal.

### Syteline team — please confirm

| Please confirm                                                             | Answer (Syteline team) |
|----------------------------------------------------------------------------|------------------------|
| Approved IDOs and properties for each Prospect-to-Cash area (exact names). |                        |
| Any custom methods for credit status, aging, order status?                 |                        |
| Rate limits / record caps; confirm read-only for the POC.                  |                        |

## API 6 — Navigation — open a form [Phase 4]

### What it is

A WebClient command or URL that opens a form, optionally filtered to one record.

### Why we need it

- Users want to go straight to the right screen after the answer ("open the invoice for this order").

### Step-by-step example: Priya asks "Open the invoices for this customer"

| Step | What happens                                                               | Who / which API   |
|------|----------------------------------------------------------------------------|-------------------|
| 1    | Chatbot checks Priya can open the invoice form (API 2).                    | Chatbot           |
| 2    | It sends the open-form command with filter CustNum = C000451 to WebClient. | Panel → WebClient |
| 3    | WebClient opens the form; Syteline still checks her access.                | SyteLine          |

### Illustrative request and response (to be confirmed)

(to be provided by the Syteline team) e.g. an open-form command with a filter:  
open form "ARInvoices" where CustNum = 'C000451'

### Without this API

The chatbot can only tell users which form to open; they navigate by hand.

### How RBAC applies

Yes — Syteline will not open a form the user has no access to.

### SyteLine team — please confirm

| Please confirm                                            | Answer (Syteline team) |
|-----------------------------------------------------------|------------------------|
| Syntax to open a form with a filter from a script or URL. |                        |
| Same window or new tab?                                   |                        |

API 7 — Write actions — NOT in this phase [Later]

What it is

Create / update / release / approve (ido/update, ido/invoke). Listed only so the boundary is clear.

Why we need it

- Not needed now: the proof of concept is read-only. Asked only to plan future phases.

Step-by-step example: Priya asks "Create an order for C000451"

| Step | What happens                                                                    | Who / which API |
|------|---------------------------------------------------------------------------------|-----------------|
| 1    | The chatbot recognises it as an action.                                         | Chatbot         |
| 2    | It replies that actions are not available in this version — nothing is created. | Chatbot         |

Illustrative request and response (to be confirmed)

Not called in the proof of concept.

Without this API

No impact now.

How RBAC applies

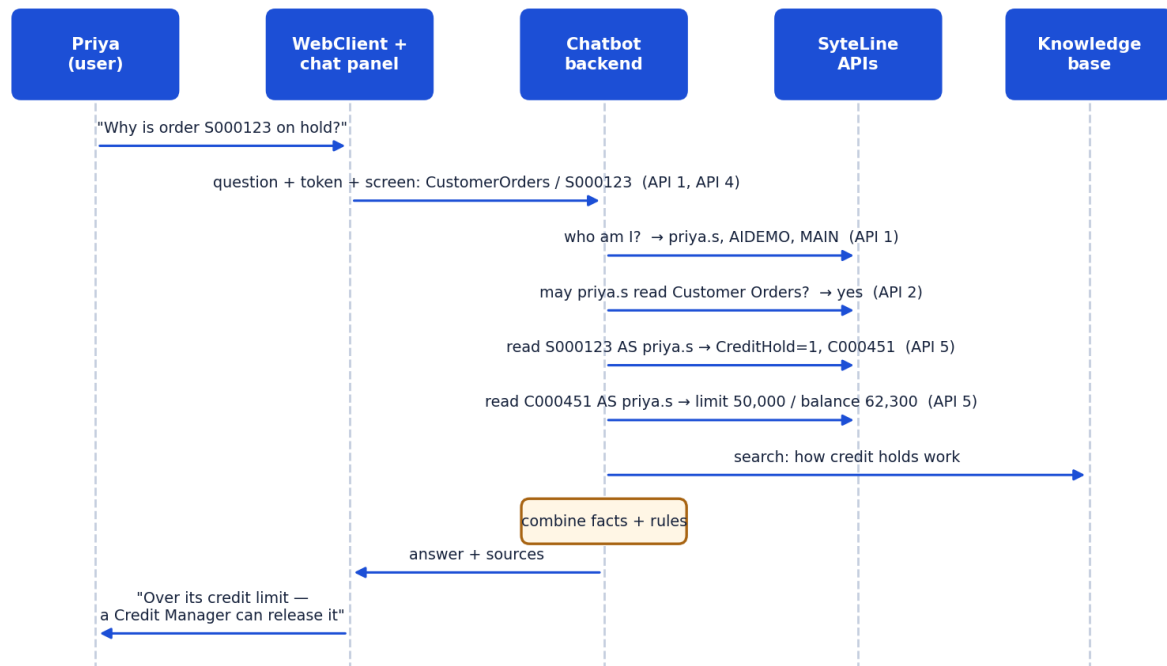
When enabled later, SyteLine enforces Insert/Update/Execute rights per user.

SyteLine team — please confirm

| Please confirm                                                                  | Answer (SyteLine team) |
|---------------------------------------------------------------------------------|------------------------|
| Which write operations (if any) may be allowed later, and with which approvals? |                        |

### 3. End to end: how the APIs work together

Example: Priya (Sales Rep) has order S000123 open and asks "Why is order S000123 on hold?"



| # | Step                                                                    | API                    |
|---|-------------------------------------------------------------------------|------------------------|
| 1 | Priya asks in the chat panel while order S000123 is open.               | —                      |
| 2 | The panel sends the question, her session token and the screen context. | API 1 + API 4          |
| 3 | The backend validates the token: priya.s, AIDEMO, MAIN.                 | API 1                  |
| 4 | It checks she may read Customer Orders (cached for a few minutes).      | API 2                  |
| 5 | It reads the order AS Priya: CreditHold = Yes, customer C000451.        | API 5                  |
| 6 | It reads the customer AS Priya: over the credit limit.                  | API 5                  |
| 7 | It searches the knowledge base for how credit holds work.               | Chatbot knowledge base |
| 8 | It writes the answer from these facts only, with sources.               | Chatbot                |

### 4. How RBAC works across the APIs

| Layer                                 | Who enforces                                           | What it protects                                                                         |
|---------------------------------------|--------------------------------------------------------|------------------------------------------------------------------------------------------|
| 1. Syteline — the real lock           | Syteline, on every IDO call made with the user's token | Forms, IDOs, fields and records the user may not see — refused or left out               |
| 2. Chatbot — explainer and gatekeeper | Chatbot permission resolver, using API 2 data          | Explaining "what can I do", hiding options, guarding the chatbot's own knowledge answers |

Same question, two users: "What is the credit limit of customer C000451?"

| User                                  | What Syteline returns (API 5, as the user) | Chatbot answer                                                                                        |
|---------------------------------------|--------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Credit Manager                        | Credit limit 50,000                        | "The credit limit of C000451 is 50,000."                                                              |
| Sales Rep without credit-field access | Credit fields hidden / not returned        | "You don't have access to credit limit information. Please contact your credit team." — never guesses |

Where RBAC could leak — and the protection

| Risk | Protection |
|------|------------|
|------|------------|

| Risk                                                    | Protection                                                                |
|---------------------------------------------------------|---------------------------------------------------------------------------|
| A shared admin account used for data calls              | Never allowed: business data is always read with the user's own token     |
| Rules checked only in the WebClient screen, not the API | SyteLine team lists them (RBAC doc D2); chatbot adds the checks           |
| Business rules outside RBAC (e.g. credit-hold release)  | Listed by SyteLine team (RBAC doc D3); chatbot checks before "you can..." |
| Stale permissions in the cache                          | Cache time agreed with SyteLine team (RBAC doc E1), default 5 minutes     |
| Knowledge answers visible to everyone                   | Chatbot-side filter by module/form (RBAC doc E4)                          |
| Chat history seen by another user                       | Already built: history locked to the user in PostgreSQL                   |
| Screen context faked by the browser                     | Context never decides identity or rights — only API 1 and SyteLine do     |

## 5. Priority and order of delivery

| Order          | APIs                                                         | What it unlocks                                                        |
|----------------|--------------------------------------------------------------|------------------------------------------------------------------------|
| 1st — blockers | API 1 Login token · API 2 Permissions · API 4 Screen context | Real user, real permissions, "which form am I on / what can I do here" |
| 2nd            | API 3 Metadata · API 5 Business data (read)                  | Answers about specific orders, customers, invoices                     |
| 3rd            | API 6 Navigation                                             | "Open this form / record"                                              |
| Later          | API 7 Write actions                                          | Only after the read-only proof of concept is approved                  |

## 6. Checklist — please tick

| Item to provide                                                            | For API    | Provided? (Y/N) | Notes / file name |
|----------------------------------------------------------------------------|------------|-----------------|-------------------|
| Way to pass the session token to the panel + validation endpoint           | 1          |                 |                   |
| API base URL and auth method (IDO REST token or ION API .ionapi)           | 1, 2, 3, 5 |                 |                   |
| Security IDO names + sample responses; read-only service account if needed | 2          |                 |                   |
| Form → IDO and field → property mapping for Prospect-to-Cash forms         | 3          |                 |                   |
| Supported WebClient script/events for form, field, record context          | 4          |                 |                   |
| Approved Prospect-to-Cash IDOs + properties (read-only), custom methods    | 5          |                 |                   |
| Open-form-with-filter syntax                                               | 6          |                 |                   |
| Test users per role in a TEST configuration                                | All        |                 |                   |
| Network access from the chatbot server; CORS / CSP / iframe settings       | All        |                 |                   |

## 7. Contacts and sign-off

| Role                            | Name | Email / phone | Date |
|---------------------------------|------|---------------|------|
| SyteLine technical contact      |      |               |      |
| SyteLine security administrator |      |               |      |
| Chatbot team lead               |      |               |      |